

-

File No.: EXP202211403

RESOLUTION OF SANCTIONING PROCEDURE

From the procedure instructed by the Spanish Agency for Data Protection and based on the following:
BACKGROUND

FIRST: FACUA - Consumers and Users Association in Action, acting on behalf of Ms. A.A.A.

(hereinafter, the claimant) filed a complaint with the Spanish Agency for Data Protection on September 14, 2022. The complaint is directed against DIGI SPAIN TELECOM, S.L. with NIF B84919760 (hereinafter, the defendant or DIGI). The reasons for the complaint are as follows:

The claimant states that DIGI provided a duplicate of her SIM card to a third party without her consent, failing to adopt the due diligence measures when verifying the identity of the requester.

She adds that this third party, using the information contained in her mobile phone, proceeded on December 25, 2021, to make various unauthorized transactions in her bank account.

Subsequently, she contacted the defendant, and they informed her that on the cited day, a duplicate of the SIM card was requested and delivered through the operator's website, at a DIGI customer service point.

She provides the following relevant documentation:

- Copy of the contract signed on January 1, 2021, with DIGI.
- Screenshots and bank statements of the fraudulent charges, emails sent to the bank for this reason.
- Complaint filed with the National Police dated December 27, 2021.
- Proof of sending the complaint to the defendant.
- Response from DIGI dated June 7, 2022.
- Screenshot of the conversation held via chat with the third party.

SECOND: On October 26, 2022, after analyzing the documentation in the file, a resolution was issued by the Director of the Spanish Agency for Data Protection, agreeing to the inadmissibility of the complaint. The resolution was notified on November 3, 2022, according to the acknowledgment of receipt in the file.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

THIRD: On November 15, 2022, a motion for reconsideration was filed, and the Director of the Spanish Agency for Data Protection resolved on March 10, 2023, to "uphold the motion for reconsideration filed by FACUA - CONSUMERS AND USERS ASSOCIATION IN ACTION, on behalf of Ms. A.A.A., against the Resolution of this Spanish Agency for Data Protection issued on October 26, 2022, so that the complaint follows the procedure established in Article 65 of Organic Law 3/2018, of December 5, on the Protection of Personal Data and the guarantee of digital rights."

FOURTH: The General Sub-Directorate for Data Inspection proceeded to carry out preliminary investigative actions to clarify the facts in question, by virtue of the functions assigned to control authorities in Article 57.1 and the powers granted in Article 58.1 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and in accordance with the provisions of Title VII, Chapter I, Section two, of the LOPDGDD, being aware of the following aspects:

(...)

The contacts recorded between the claimant and the defendant have been requested, as well as the actions taken by the managers in relation to them:

- On 12/25/2021, there is a contact via WhatsApp from someone who identified as the claimant, followed by the generation of the SIM duplicate.
- There is a contact from the claimant communicating that her identity has been impersonated to duplicate her SIM card. It is noted that "SOMEONE IS IMPERSONATING THE HOLDER and they are stealing money via BIZUM. Do not manage anything through social networks or customer service chat

for greater security."

FIFTH: According to the report collected from the AXESOR tool, the entity DIGI SPAIN TELECOM, S.L. is a large company established in 2006, with a turnover of 364,201,000 euros in 2021.

SIXTH: On July 26, 2023, the Director of the Spanish Agency for Data Protection agreed to initiate sanctioning proceedings against the defendant for the alleged infringement of Article 6.1 of the GDPR, classified under Article 83.5 of the GDPR.

SEVENTH: The Agreement to Initiate was notified through the Unique Electronic Address service (DEHÚ) certifying: "date of acceptance by the defendant on July 31, 2023, at 14:21."

There is no record that the defendant has submitted a written statement regarding the same.

Article 64.2.f) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter LPACAP) - a provision of which the defendant was informed in the opening agreement of the procedure - establishes that if no allegations are made within the established period regarding the content of the initiation agreement, when it contains a precise statement regarding the attributed responsibility, it may be considered a proposal for resolution. In the C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

3/10

In the present case, the initiation agreement of the sanctioning file determined the facts on which the accusation was based, the infringement of the GDPR attributed to the respondent, and the sanction that could be imposed. Therefore, considering that the respondent has not made any allegations against the initiation agreement of the file and in accordance with the provisions of Article 64.2.f) of the LPACAP, the aforementioned initiation agreement is considered in this case as a proposal for resolution.

In view of all that has been acted upon, the Spanish Agency for Data Protection considers the following in this procedure:

PROVEN FACTS

1. The complainant filed a complaint with this Agency on April 4, 2023, stating that DIGI provided a duplicate of her SIM card to a third party without her consent on December 25, 2021, using the information contained in her mobile phone, and various banking transactions were carried out on that same date.
2. It is recorded that on December 25, 2021, a third party who identified themselves as the complainant contacted DIGI via WhatsApp, and subsequently, DIGI generated the duplicate of the SIM card.
3. The complainant contacted DIGI on the same day, reporting that her identity had been impersonated to duplicate her SIM card, and she was provided with another SIM on December 28, 2021.

LEGAL GROUNDS

I

Competence

In accordance with the powers granted to each supervisory authority by Article 58.2 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and as established in Articles 47, 48.1, 64.2, and 68.1 of Organic Law 3/2018, of December 5, on Personal Data Protection and the guarantee of digital rights (hereinafter, LOPDGDD), the Director of the Spanish Agency for Data Protection is competent to initiate and resolve this procedure.

Furthermore, Article 63.2 of the LOPDGDD states: "The procedures processed by the Spanish Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679, by this organic law, by the regulatory provisions issued for its development, and, in so far as they do not contradict them, subsidiarily by the general rules on administrative procedures."

II

Obligation Breached

It is necessary to point out that Article 4.1 of the GDPR defines "personal data" as "any information relating to an identified or identifiable natural person ('data subject'); an identifiable natural person is one who can be identified, directly or indirectly, in particular by reference to an identifier, such as a name, an identification number, location data, an online identifier, or to one or more factors specific to the physical, physiological, genetic, mental, economic, cultural, or social identity of that natural person;"

In this regard, it is important to clarify that the SIM card is inserted within the mobile terminal. It is a smart card, in physical format and small dimensions, that contains a chip where the subscriber's service key is stored, used to identify themselves to the network, that is, the mobile phone line number of the customer MSISDN (Mobile Station Integrated Services Digital Network), as well as the subscriber's personal identification number IMSI (International Mobile Subscriber Identity), but it can also provide other types of data such as information about the phone directory or call and message logs.

On the other hand, the issuance of a duplicate SIM card involves the processing of the personal data of its holder since any person whose identity can be determined, directly or indirectly, in particular by reference to an identifier (Article 4.1 of the GDPR) is considered an identifiable natural person.

Therefore, the SIM card identifies a phone number, and this number, in turn, identifies its holder. In this sense, the Judgment of the CJEU in case C-101/2001 (Lindqvist) of November 6, 2003, paragraph 24, Rec. 2003 p. I-12971 states: "The concept of 'personal data' used in Article 3(1) of Directive 95/46 includes, according to the definition in Article 2(a) of that Directive, 'any information relating to an identified or identifiable natural person'. This concept undoubtedly includes a person's name along with their phone number or other information relating to their working conditions or hobbies."

In summary, both the data processed to issue a duplicate SIM card and the SIM card (Subscriber Identity Module) that unequivocally identifies the subscriber on the network are personal data, and their processing must comply with data protection regulations.

Thus, the respondent is accused of committing an infringement for violating Article 6 of the GDPR, "Lawfulness of processing," which states in its paragraph 1 the circumstances under which the processing of third-party data is considered lawful:

"1. Processing shall be lawful only if at least one of the following applies:

a) the data subject has given consent to the processing of their personal data for one or more specific purposes;

b) processing is necessary for the performance of a contract to which the data subject is party or to take steps at the request of the data subject prior to entering into a contract;

5/10

c) the processing is necessary for compliance with a legal obligation to which the data controller is subject;

d) the processing is necessary to protect vital interests of the data subject or of another natural person;

e) the processing is necessary for the performance of a task carried out in the public interest or in the exercise of official authority vested in the data controller;

f) the processing is necessary for the purposes of the legitimate interests pursued by the data controller or by a third party, provided that such interests do not override the interests or the fundamental rights and freedoms of the data subject which require protection of personal data, in particular when the data subject is a child. The provisions of item f) of the first paragraph shall not apply to processing carried out by public authorities in the exercise of their functions.

In this case, it is established that on December 25, 2021, DIGI processed the issuance of a duplicate SIM card belonging to the claimant, and that according to DIGI, the alleged impersonator surpassed the established protocols.

In this regard, the procedure established by DIGI at the time the events occurred (...).

However, it should be noted that SIM Swapping is a fraud that allows identity theft by hijacking the phone number through obtaining a duplicate of the SIM card.

In any case, the operator must be able to demonstrate that for this specific case, it followed the verification protocols implemented at the time of requesting a duplicate of the SIM card. The result was that the respondent issued the SIM card to a third party who was not the holder of the line.

In light of the above, DIGI fails to demonstrate that this procedure was followed.

In fact, according to the identification procedure described by the respondent, which would have been in force at the time the events occurred, at the establishment where the duplicate SIM card was issued, the original identification document should have been verified, and thus, if this operation had been carried out correctly, the duplicate should have been denied.

In the explanation provided by the respondent, there is no indication of what the specific cause could have been that led to the issuance of the duplicate. In any case, the respondent has not been able to demonstrate that the procedure implemented by itself was followed for this case, since, had it been done, the duplicate of the SIM card should have been denied.

Based on the above, in the analyzed case, the diligence employed by the respondent to identify the person who requested a duplicate of the SIM card is called into question.

In accordance with the available evidence, it is estimated that the conduct of the respondent could violate Article 6.1 of the GDPR and could constitute an infringement as defined in Article 83.5.a) of the aforementioned Regulation 2016/679.

In this regard, Recital 40 of the GDPR states:

“(40) For processing to be lawful, personal data must be processed with the consent of the data subject or on some other legitimate basis laid down by law, whether in this Regulation or by virtue of other Union or Member State law to which this Regulation relates, including the necessity of complying with a legal obligation to which the data controller is subject or the necessity of performing a contract to which the data subject is party or in order to take steps at the request of the data subject prior to entering into a contract.”

III

Classification and Qualification of the Infringement

The infringement is classified in Article 83.5 of the GDPR, which considers as such:

“5. Infringements of the following provisions shall be subject to administrative fines of up to 20,000,000 EUR or, in the case of an undertaking, an amount equivalent to up to 4% of the total annual global turnover of the preceding financial year, opting for the higher amount:

a) The basic principles for processing, including the conditions for consent under Articles 5, 6, 7, and 9.”

The LOPDGD, for the purposes of the prescription of the infringement, qualifies in its Article 72.1 as a very serious infringement, with a prescription period of three years in this case, “b) The processing of personal data without any of the conditions for lawful processing established in Article 6 of Regulation (EU) 2016/679.”

IV

Sanction

In order to establish the administrative fine that should be imposed, the provisions contained in Articles 83.1 and 83.2 of the GDPR must be observed, which state:

“1. Each supervisory authority shall ensure that the imposition of administrative fines under this article for the infringements of this Regulation indicated in paragraphs 4, 9, and 6 are, in each individual case, effective, proportionate, and dissuasive.”

“2. Administrative fines shall be imposed, depending on the circumstances of each individual case, as an additional or substitute measure to those provided for in the

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

7/10

Article 58, paragraph 2, letters a) to h) and j). In deciding the imposition of an administrative fine and its amount in each individual case, the following will be duly taken into account:

- a) the nature, severity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing operation in question, as well as the number of affected parties and the level of damage and harm they have suffered;
- b) the intentionality or negligence in the infringement;
- c) any measures taken by the data controller or processor to mitigate the damage and harm suffered by the affected parties;
- d) the degree of responsibility of the data controller or processor, considering the technical or organizational measures they have applied under Articles 25 and 32;
- e) any previous infringement committed by the data controller or processor;
- f) the degree of cooperation with the supervisory authority in order to remedy the infringement and mitigate the possible adverse effects of the infringement;
- g) the categories of personal data affected by the infringement;
- h) the manner in which the supervisory authority became aware of the infringement, in particular whether the data controller or processor reported the infringement and, if so, to what extent;
- i) when the measures indicated in Article 58, paragraph 2, have been previously ordered against the data controller or processor in relation to the same matter, compliance with such measures;
- j) adherence to codes of conduct under Article 40 or to certification mechanisms approved under Article 42, and
- k) any other aggravating or mitigating factor applicable to the circumstances of the case, such as financial benefits obtained or losses avoided, directly or indirectly, through the infringement.”

Within this section, the LOPDGDD provides in its Article 76, titled “Sanctions and corrective measures”:

“1. The sanctions provided for in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679 shall be applied taking into account the criteria for graduation established in paragraph 2 of the aforementioned article.

2. In accordance with the provisions of Article 83.2.k) of Regulation (EU) 2016/679, the following may also be taken into account:

- a) The continued nature of the infringement.
- b) The connection of the infringer's activity with the processing of personal data.
- c) The benefits obtained as a result of the commission of the infringement.
- d) The possibility that the conduct of the affected party may have induced the commission of the infringement.
- e) The existence of a merger by absorption after the commission of the infringement, which cannot be attributed to the absorbing entity.
- f) The impact on the rights of minors.
- g) Having, when not mandatory, a data protection officer.
- h) The voluntary submission by the data controller or processor to alternative dispute resolution mechanisms, in cases where there are disputes between them and any affected party.

3. It will be possible, additionally or alternatively, to adopt, when appropriate, the remaining corrective measures referred to in Article 83.2 of Regulation (EU) 2016/679.”

According to the transcribed provisions, and without prejudice to what results from the instruction of the procedure, for the purpose of determining the amount of the fine to be imposed on the entity claimed as responsible for an infringement classified in Article 83.5.a) of the GDPR and 72.1 b) of the LOPDGDD, the following factors are considered concurrent in the present case:

As aggravating circumstances:

- The circumstance of Article 83.2.e) GDPR: “Any previous infringement committed by the data controller or processor.”

Recital 148 of the GDPR states, “In order to strengthen the application of the rules of this Regulation [...]” and indicates in this regard that “Special attention must nevertheless be paid to the nature, severity, and duration of the infringement, to its intentional nature [...] or to any relevant infringement [...]”.

Thus, in accordance with paragraph e) of Article 83.2. GDPR, in determining the amount of the administrative fine, all previous infringements of the data controller or processor must be assessed in

order to gauge the unlawfulness of the analyzed conduct or the culpability of the infringing party. Moreover, a correct interpretation of the provision of Article 83.2.e) GDPR cannot overlook the purpose pursued by the norm: to decide the amount of the administrative fine in the individual case presented, always ensuring that the sanction is proportional, effective, and dissuasive.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

9/10

There are numerous sanctioning procedures processed by the AEPD in which the respondent has been sanctioned for the infringement of Article 6.1 of the GDPR:

i. EXP 202104009 Resolution issued on March 15, 2023, imposing a fine of 70,000 euros. The facts concerned a fraudulent duplicate of the SIM card without legitimacy.

ii. EXP202201226. Resolution issued on March 14, 2023, imposing a fine of 70,000 euros. The facts concerned a fraudulent duplicate of the SIM card without legitimacy.

iii. EXP202204881 Resolution issued on June 2, 2023, imposing a fine of 70,000 euros. The facts concerned a fraudulent duplicate of the SIM card without legitimacy.

- The evident link between the business activity of the respondent and the processing of personal data of clients or third parties (Article 83.2.k of the GDPR in relation to Article 76.2.b of the LOPDGDD).

The Judgment of the National Court of October 17, 2007 (rec. 63/2006), regarding entities whose activity involves continuous processing of customer data, indicates that "...the Supreme Court has understood that there is negligence whenever a legal duty of care is neglected, that is, when the offender does not behave with the required diligence. In assessing the degree of diligence, the professionalism or lack thereof of the subject must be especially weighed, and there is no doubt that, in the case now examined, when the activity of the appellant involves constant and abundant handling of personal data, it must be insisted upon the rigor and exquisite care to comply with the legal provisions in this regard."

As mitigating circumstances:

The respondent effectively addressed the incident that was the subject of the complaint (art. 83.2 c).

The balance of the circumstances contemplated in Article 83.2 of the GDPR, regarding the infringement committed by violating the provisions of its Article 6.1 of the GDPR, allows for the imposition of a fine of 200,000 euros (two hundred thousand euros).

Therefore, in accordance with the applicable legislation and having assessed the criteria for the graduation of the sanction whose existence has been established, the Director of the Spanish Agency for Data Protection RESOLVES:

FIRST: TO IMPOSE on DIGI SPAIN TELECOM, S.L., with NIF B84919760, for an infringement of Article 6.1 of the GDPR, classified under Article 83.5 of the GDPR, a fine of 200,000 euros (two hundred thousand euros).

SECOND: TO NOTIFY this resolution to DIGI SPAIN TELECOM, S.L.

THIRD: TO WARN the sanctioned party that they must pay the imposed fine once this resolution becomes enforceable, in accordance with the provisions of art. 98.1.b) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter LPACAP), within the payment period.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

10/10

voluntary payment established in Article 68 of the General Collection Regulation, approved by Royal Decree 939/2005, of July 29, in relation to Article 62 of Law 58/2003, of December 17, by making the payment, indicating the NIF of the sanctioned party and the procedure number that appears in the heading of this document, into the restricted account No.

IBAN: ES00-0000-0000-0000-0000-0000 (BIC/SWIFT Code: CAIXESBBXXX), opened in the name of

the Spanish Agency for Data Protection at the banking entity CAIXABANK, S.A. Otherwise, collection will proceed in the executive period.

Upon receipt of the notification and once it is executive, if the date of executiveness falls between the 1st and the 15th of each month, inclusive, the deadline for making the voluntary payment will be until the 20th of the following month or the next business day thereafter, and if it falls between the 16th and the last day of each month, inclusive, the payment deadline will be until the 5th of the second following month or the next business day thereafter.

In accordance with the provisions of Article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

Against this resolution, which concludes the administrative procedure in accordance with Article 48.6 of the LOPDGDD, and in accordance with the provisions of Article 123 of the LPACAP, the interested parties may optionally file a motion for reconsideration before the Director of the Spanish Agency for Data Protection within one month from the day following the notification of this resolution or directly file a contentious-administrative appeal before the Contentious-Administrative Chamber of the National Court, in accordance with the provisions of Article 25 and Section 5 of the fourth additional provision of Law 29/1998, of July 13, regulating the Contentious-Administrative Jurisdiction, within two months from the day following the notification of this act, as provided in Article 46.1 of the aforementioned Law. Finally, it is noted that in accordance with the provisions of Article 90.3 a) of the LPACAP, the firm resolution in the administrative procedure may be provisionally suspended if the interested party expresses their intention to file a contentious-administrative appeal. If this is the case, the interested party must formally communicate this fact by means of a written document addressed to the Spanish Agency for Data Protection, submitting it through the Electronic Registry of the Agency [<https://sedeagpd.gob.es/sede-electronica-web/>], or through any of the other registries provided for in Article 16.4 of Law 39/2015, of October 1. They must also provide the Agency with documentation that proves the effective filing of the contentious-administrative appeal. If the Agency is not aware of the filing of the contentious-administrative appeal within two months from the day following the notification of this resolution, it will consider the provisional suspension to be concluded.

Mar España Martí

Director of the Spanish Agency for Data Protection

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es